

**TỔNG LIÊN ĐOÀN LAO ĐỘNG VIỆT NAM
TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG
KHOA CÔNG NGHỆ THÔNG TIN**



**Nguyễn Thành Đạt - 52400007
Nguyễn Văn Duy – 52400010
Lê Tiến Đạt - 52400105**

HỆ THỐNG QUẢN LÝ BÁN HÀNG ĐIỆN THOẠI VÀ PHỤ KIỆN

BÁO CÁO CUỐI KỲ LẬP TRÌNH WEB VÀ ỨNG DỤNG

THÀNH PHỐ HỒ CHÍ MINH, NĂM 2026

**TỔNG LIÊN ĐOÀN LAO ĐỘNG VIỆT NAM
TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG
KHOA CÔNG NGHỆ THÔNG TIN**



**Nguyễn Thành Đạt - 52400007
Nguyễn Văn Duy – 52400010
Lê Tiến Đạt - 52400105**

HỆ THỐNG QUẢN LÝ BÁN HÀNG ĐIỆN THOẠI VÀ PHỤ KIỆN

BÁO CÁO CUỐI KỲ LẬP TRÌNH WEB VÀ ỨNG DỤNG

**Người hướng dẫn
ThS.NCS. Vũ Đình Hồng**

THÀNH PHỐ HỒ CHÍ MINH, NĂM 2026

LỜI CẢM ƠN

Chúng em xin chân thành cảm ơn đến giảng viên ThS.NCS. Vũ Đình Hồng. Trong quá trình nghiên cứu tìm hiểu và học tập môn học Lập trình web và ứng dụng, chúng em đã nhận được rất nhiều sự quan tâm, giúp đỡ nhiệt tình, hướng dẫn tận tâm và tâm huyết của thầy Vũ Đình Hồng. Thầy đã giúp chúng em tích lũy thêm nhiều kiến thức về môn này để có thể hoàn thành được bài báo cáo này. Và bên cạnh đó, chúng em cũng cảm ơn những người bạn xung quanh cùng nhau hỗ trợ và làm nên bài báo cáo này. Chúng em xin gửi lời cảm ơn trân trọng đến thầy và các bạn đã cùng nhau làm bài báo cáo “Báo cáo cuối kỳ môn Lập trình web và ứng dụng”.

Mặc dù đã dành nhiều thời gian và nỗ lực để hoàn thành bài báo cáo này, nhưng do sự hạn chế về mặt kiến thức nên bài làm khó tránh khỏi những thiếu sót. Chúng em kính mong nhận được những lời góp ý của quý thầy, cô để bài làm này ngày càng hoàn thiện hơn. Chúng em xin chân thành cảm ơn!

TP. Hồ Chí Minh, ngày 25 tháng 03 năm 2026

Tác giả

Duy

Nguyễn Văn Duy

Đạt

Lê Tiến Đạt

Đạt

Nguyễn Thành Đạt

CÔNG TRÌNH ĐƯỢC HOÀN THÀNH TẠI TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG

Tôi xin cam đoan đây là công trình nghiên cứu của riêng chúng tôi và được sự hướng dẫn khoa học của ThS.NCS.Vũ Đình Hồng. Các nội dung nghiên cứu, kết quả trong đề tài này là trung thực và chưa công bố dưới bất kỳ hình thức nào trước đây. Những số liệu trong các bảng biểu phục vụ cho việc phân tích, nhận xét, đánh giá được chính tác giả thu thập từ các nguồn khác nhau có ghi rõ trong phần tài liệu tham khảo.

Ngoài ra, trong Dự án còn sử dụng một số nhận xét, đánh giá cũng như số liệu của các tác giả khác, cơ quan tổ chức khác đều có trích dẫn và chú thích nguồn gốc.

Nếu phát hiện có bất kỳ sự gian lận nào tôi xin hoàn toàn chịu trách nhiệm về nội dung Dự án của mình. Trường Đại học Tôn Đức Thắng không liên quan đến những vi phạm tác quyền, bản quyền do tôi gây ra trong quá trình thực hiện (nếu có).

TP. Hồ Chí Minh, ngày 25 tháng 03 năm 2026

Tác giả

Duy

Nguyễn Văn Duy

Đạt

Lê Tiến Đạt

Đạt

Nguyễn Thành Đạt

TÓM TẮT

Dưới đây là nội dung báo cáo cuối kỳ của học phần Lập trình Web và Ứng dụng.

Bài báo cáo bao gồm các chương trình bày chi tiết từ cơ sở lý thuyết, phân tích thiết kế hệ thống (thông qua sơ đồ Usecase và ERD), cho đến quá trình hiện thực hóa và đánh giá kết quả của Hệ thống Quản lý Bán hàng Điện thoại (3D Phone POS).

Nội dung cụ thể của đồ án bao gồm việc xây dựng một hệ thống hoàn chỉnh dựa trên mô hình kiến trúc MVC bằng PHP thuần và hệ quản trị cơ sở dữ liệu MySQL, giải quyết 5 bài toán nghiệp vụ chính:

1. **Quản lý tài khoản và người dùng:** Xây dựng cơ chế đăng nhập, phân quyền và quản lý hồ sơ giữa Quản trị viên (Admin) và Nhân viên bán hàng (Sales Staff).
2. **Quản lý sản phẩm và danh mục:** Xử lý các thao tác thêm, sửa, xóa sản phẩm và kiểm soát hàng hóa trong kho.
3. **Quản lý khách hàng:** Tự động tạo tài khoản và theo dõi lịch sử mua hàng của khách hàng.
4. **Xử lý giao dịch (POS):** Thực hiện nghiệp vụ bán hàng, quản lý giỏ hàng, xử lý thanh toán và in hóa đơn PDF.
5. **Báo cáo và phân tích:** Trực quan hóa dữ liệu thống kê, tổng hợp doanh thu và số lượng đơn hàng theo các mốc thời gian khác nhau.

MỤC LỤC

CHƯƠNG 1. MỞ ĐẦU VÀ TỔNG QUAN ĐỀ TÀI.....	1
1.1 Trình bày về đề tài và lý do thực hiện.....	1
1.2 Những yêu cầu của đề tài cần thực hiện	1
1.2.1 Yêu cầu về phạm vi và kỹ thuật.....	1
1.2.2 Yêu cầu về chức năng nghiệp vụ.....	2
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT.....	2
2.1 Mô hình kiến trúc MVC (Model – View – Controller).....	2
2.2 Lập trình hướng đối tượng với PHP.....	3
2.3 Quản trị cơ sở dữ liệu MySQL và tầng truy cập PDO.....	4
2.4 Lý thuyết bảo mật và tối ưu hóa truy vấn nâng cao	4
2.5 Các công nghệ Front-end và thư viện tiện ích	4
CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ	5
3.1 Phân tích thiết kế thông qua sơ đồ Use Case	6
3.2 Phân tích thiết kế cơ sở dữ liệu thông qua sơ đồ ERD	8
3.3 Phân tích kiến trúc thông qua sơ đồ lớp (Class Diagram)	11
3.4 Phân tích luồng nghiệp vụ thông qua sơ đồ tuần tự (Sequence Diagram).....	12
3.4.1 Luồng xử lý giao dịch tại quầy	12
3.4.2 Luồng cấp tài khoản và xác thực nhân viên mới	13
CHƯƠNG 4. HIỆN THỰC HỆ THỐNG.....	13
4.1 Tổ chức cấu trúc mã nguồn.....	13
4.2 Hiện thực cơ chế Front Controller và Định tuyến (Routing)	14
4.3 Hiện thực cơ chế Middleware bảo vệ và phân quyền	15

4.4 Hiện thực luồng thuật toán tạo nhân viên mới	16
4.5 Hiện thực luồng xử lý giao dịch POS (Thanh toán thời gian thực)	17
CHƯƠNG 5. KẾT QUẢ ĐẠT ĐƯỢC.....	18
5.1 Giao diện và chức năng đã hoàn thành	18
5.2 Năm điểm kỹ thuật nổi bật	19
5.3 Kết quả kiểm thử hệ thống	21
CHƯƠNG 6. KẾT LUẬN.....	24
6.1 Những kết quả đã đạt được và ưu điểm của hệ thống	24
6.2 Khuyết điểm và Hạn chế	24
6.3 Hướng phát triển tương lai	25
TÀI LIỆU THAM KHẢO	27

CHƯƠNG 1. MỞ ĐẦU VÀ TỔNG QUAN ĐỀ TÀI

1.1 Trình bày về đề tài và lý do thực hiện

Trong bối cảnh thương mại bán lẻ tại Việt Nam ngày càng phát triển, các cửa hàng kinh doanh thiết bị điện tử và phụ kiện công nghệ đang đối mặt với áp lực lớn trong việc tối ưu hóa quy trình vận hành. Thực tế cho thấy, nhiều cơ sở bán lẻ vừa và nhỏ vẫn đang xử lý các giao dịch theo phương pháp thủ công hoặc sử dụng các phần mềm đơn lẻ, thiếu tính đồng bộ. Điều này dẫn đến nhiều hệ lụy nghiêm trọng như: sai sót trong quá trình tính tiền, khó khăn trong việc tra cứu lịch sử giao dịch, thiếu công cụ phân tích kinh doanh trực quan và không kiểm soát chặt chẽ được hoạt động của nhân viên.

Để giải quyết triệt để các vấn đề trên, hệ thống Point of Sale (POS) ra đời như một giải pháp toàn diện, tích hợp toàn bộ quy trình từ quản lý sản phẩm, xử lý thanh toán tại quầy, quản lý thông tin khách hàng, đến báo cáo thống kê doanh thu.

Nhận thấy đây là một bài toán thực tiễn có tính ứng dụng cao, đồng thời là cơ hội để bao quát và vận dụng toàn bộ các kỹ năng lập trình web đã được học trong học phần, nhóm quyết định lựa chọn đề tài: "**Xây dựng hệ thống Quản lý bán hàng Điện thoại – 3D Phone POS**". Đề tài này hướng đến việc xây dựng một ứng dụng web hoàn chỉnh phục vụ cho hoạt động vận hành nội bộ của một cửa hàng bán lẻ, với hai nhóm người dùng chính là Quản trị viên (Admin) và Nhân viên bán hàng (Sales Staff).

1.2 Những yêu cầu của đề tài cần thực hiện

Để đảm bảo hệ thống hoạt động hiệu quả, bám sát thực tiễn và đáp ứng đúng tiêu chí đánh giá của học phần, đề tài đặt ra các yêu cầu cụ thể về chức năng và phạm vi kỹ thuật như sau:

1.2.1 Yêu cầu về phạm vi và kỹ thuật

- **Nền tảng và Kiến trúc:** Xây dựng ứng dụng web dựa trên kiến trúc MVC (Model - View - Controller), truy cập qua trình duyệt web.

- **Bảo mật:** Đảm bảo an toàn dữ liệu ở nhiều tầng, bao gồm việc xây dựng hệ thống xác thực và phân quyền người dùng chặt chẽ, an toàn.
- **Hiệu năng:** Tối ưu hóa hiệu năng truy vấn cơ sở dữ liệu để hệ thống vận hành mượt mà.
- **Đối tượng sử dụng:** Giới hạn phạm vi người dùng là Nhân viên bán hàng và Quản trị viên. Khách hàng mua hàng không trực tiếp sử dụng hệ thống.

1.2.2 Yêu cầu về chức năng nghiệp vụ

Hệ thống phải cung cấp đầy đủ các mô-đun chức năng quản lý nghiệp vụ, cụ thể:

- **Quản lý tài khoản và người dùng:** Hỗ trợ phân quyền chặt chẽ; đặc biệt yêu cầu xây dựng cơ chế cấp phép (onboarding) an toàn cho nhân viên mới thông qua email.
- **Quản lý sản phẩm và danh mục:** Cho phép quản trị viên thêm, sửa, xóa, phân loại sản phẩm và kiểm soát hàng hóa.
- **Xử lý giao dịch POS:** Xây dựng mô-đun bán hàng trực quan, nhanh chóng, cho phép tra cứu sản phẩm bằng tên hoặc mã vạch và tự động cập nhật giỏ hàng theo thời gian thực.
- **Quản lý khách hàng:** Quản lý thông tin và lưu trữ lịch sử giao dịch của từng khách hàng.
- **Báo cáo và phân tích:** Triển khai mô-đun thống kê với các biểu đồ trực quan, hỗ trợ lọc và xem báo cáo theo nhiều mốc thời gian khác nhau.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT

2.1 Mô hình kiến trúc MVC (Model – View – Controller)

MVC là một mẫu kiến trúc phần mềm (Architectural Pattern) phân tách ứng dụng thành ba thành phần độc lập nhằm dễ dàng quản lý và mở rộng:

- **Model:** Chịu trách nhiệm về logic dữ liệu, giao tiếp trực tiếp với cơ sở dữ liệu thông qua PDO để thực hiện các thao tác CRUD.

- **View:** Chịu trách nhiệm về giao diện hiển thị, nhận dữ liệu từ Controller và kết xuất (render) ra HTML gửi về trình duyệt.
- **Controller:** Đóng vai trò điều phối trung gian, nhận request từ người dùng, gọi Model xử lý dữ liệu rồi chỉ định View tương ứng để hiển thị.

Việc tự xây dựng mô hình MVC từ đầu giúp nhóm nắm vững nguyên lý luồng dữ liệu thay vì phụ thuộc vào các framework có sẵn.

Luồng xử lý request trong hệ thống 3D Phone POS:

Để làm rõ nguyên lý hoạt động của kiến trúc MVC tự xây dựng, hệ thống xử lý một vòng đời yêu cầu (Request Lifecycle) theo trình tự 6 bước chặt chẽ như sau:

- **Tiếp nhận yêu cầu (Request):** Trình duyệt gửi Request HTTP đến máy chủ. Yêu cầu này bị chặn lại và đi qua điểm chạm duy nhất là tệp `index.php` (đóng vai trò Front Controller / Router).
- **Phân tích định tuyến (Routing):** Router thực hiện phân tích chuỗi URL để xác định chính xác Controller và Action (phương thức) mục tiêu cần thực thi.
- **Khởi tạo logic:** Controller tương ứng được khởi tạo. Để chuẩn bị xử lý nghiệp vụ, Controller sẽ gọi và khởi tạo các đối tượng Model(s) cần thiết.
- **Truy xuất dữ liệu:** Controller gọi các phương thức của Model. Lúc này, Model tương tác trực tiếp với cơ sở dữ liệu (qua PDO) để lấy hoặc thao tác dữ liệu, sau đó trả kết quả về cho Controller.
- **Truyền tải dữ liệu:** Controller đóng gói dữ liệu nhận được từ Model, kết hợp với các logic nghiệp vụ cuối cùng và truyền toàn bộ khối lượng dữ liệu này sang tệp View tương ứng.
- **Kết xuất và Phản hồi (Response):** View tiếp nhận dữ liệu, kết xuất (render) mã HTML tĩnh và trả về hệ thống dưới dạng Response HTTP để hiển thị trực quan trên trình duyệt của người dùng.

2.2 Lập trình hướng đối tượng với PHP

Dự án sử dụng ngôn ngữ PHP thuần (phiên bản 8.x) kết hợp sâu sắc với tư tưởng Lập trình hướng đối tượng (OOP). Mỗi thành phần trong hệ thống MVC

(Controller, Model) đều được triển khai dưới dạng một lớp (class) độc lập, áp dụng triệt để các tính chất như tính đóng gói (encapsulation) thông qua các access modifiers (public, private) để bảo vệ luồng dữ liệu.

2.3 Quản trị cơ sở dữ liệu MySQL và tầng truy cập PDO

Hệ thống sử dụng MySQL làm hệ quản trị cơ sở dữ liệu quan hệ (RDBMS). Để tương tác với MySQL, đề tài áp dụng PDO (PHP Data Objects) – một lớp trừu tượng truy cập dữ liệu. Ưu điểm cốt lõi của PDO là hỗ trợ **Prepared Statements**, cho phép tham số hóa các câu truy vấn SQL, từ đó ngăn chặn triệt để các lỗ hổng tấn công SQL Injection – một tiêu chuẩn bảo mật bắt buộc đối với các ứng dụng web hiện đại.

2.4 Lý thuyết bảo mật và tối ưu hóa truy vấn nâng cao

- **Mã hóa mật khẩu với Bcrypt:** Bcrypt là hàm băm mật khẩu được thiết kế để chống lại các tấn công brute-force nhờ chi phí tính toán có thể điều chỉnh (work factor). PHP cung cấp hàm `password_hash()` để băm dữ liệu, đảm bảo mật khẩu thực tế không bao giờ bị lưu trữ dưới dạng văn bản thuần.
- **Truy vấn SARGable:** SARGable (Search ARGument ABLE) là nguyên tắc viết câu truy vấn SQL sao cho Database Engine có thể tận dụng cấu trúc **Index**. Việc tránh bọc các cột dữ liệu trong hàm (ví dụ: dùng `BETWEEN` thay vì hàm `DATE()`) giúp hệ thống tránh được tình trạng quét toàn bộ bảng (Full Table Scan), giữ vững hiệu năng khi lượng dữ liệu lớn.

2.5 Các công nghệ Front-end và thư viện tiện ích

Bên cạnh cấu trúc Back-end, đề tài ứng dụng các công nghệ và thư viện mã nguồn mở để hoàn thiện trải nghiệm người dùng và nghiệp vụ hệ thống:

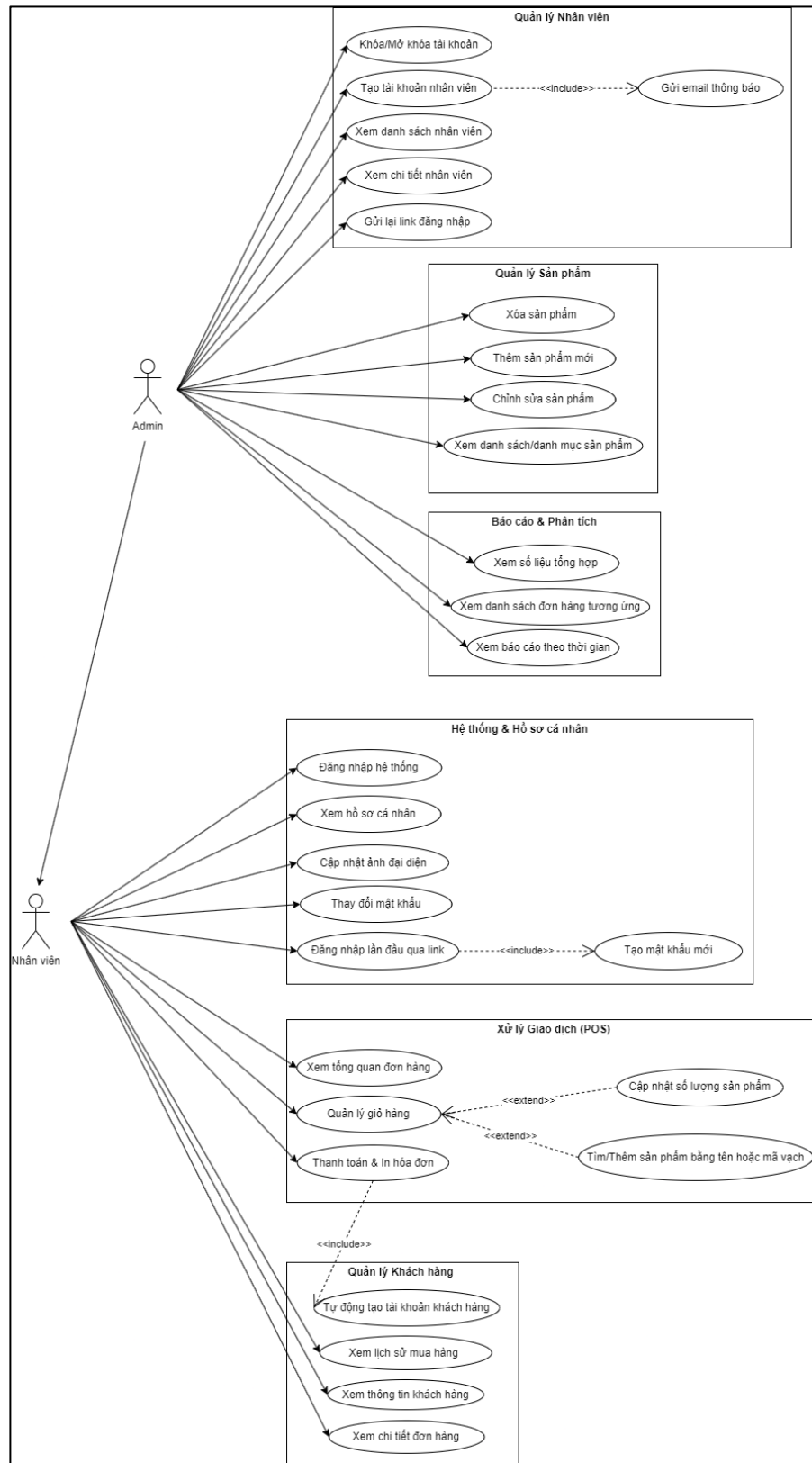
- **Giao diện và Xử lý bất đồng bộ:** Sử dụng framework Bootstrap 5 để xây dựng giao diện responsive, kết hợp cùng jQuery (AJAX) để xử lý các tác vụ cập nhật dữ liệu một phần (như thêm giỏ hàng) mà không cần tải lại trang.

- **Thư viện chuyên dụng:** Tích hợp **PHPMailer** để xử lý giao thức gửi thư điện tử bảo mật (SMTP), **Dompdf** để kết xuất hóa đơn thanh toán từ HTML sang định dạng PDF, và **Chart.js** để vẽ các biểu đồ phân tích kinh doanh trực quan.

CHƯƠNG 3. PHÂN TÍCH THIẾT KẾ

Quá trình phân tích và thiết kế Hệ thống Quản lý Bán hàng Điện thoại (3D Phone POS) được thực hiện theo phương pháp tiếp cận hướng đối tượng (Object-Oriented Analysis and Design - OOAD). Dưới đây là các mô hình chuẩn hóa UML và sơ đồ thực thể liên kết (ERD) nhằm làm rõ luồng nghiệp vụ và cấu trúc dữ liệu của hệ thống.

3.1 Phân tích thiết kế thông qua sơ đồ Use Case



Hình 3-1. Use Case

Hệ thống được thiết kế phục vụ cho hai tác chính với các phân quyền và chức năng tách biệt.

- **Tác nhân 1: Quản trị viên (Admin)**

Là người có quyền hạn cao nhất, chịu trách nhiệm quản trị toàn bộ hoạt động của hệ thống. Các nhóm Use Case chính bao gồm:

- **Quản lý Nhân viên:** Tạo tài khoản nhân viên mới (tích hợp <<include>> Gửi email thông báo tự động), xem danh sách và chi tiết nhân viên, Khóa/Mở khóa tài khoản, và Gửi lại liên kết đăng nhập.
- **Quản lý Sản phẩm và Danh mục:** Xem, Thêm, Chỉnh sửa và Xóa sản phẩm/danh mục.
- **Báo cáo và Thống kê:** Xem số liệu tổng hợp (bao gồm chỉ số Tổng lợi nhuận - đặc quyền riêng của Admin), truy xuất danh sách đơn hàng và xem báo cáo theo từng mốc thời gian.

- **Tác nhân 2: Nhân viên bán hàng (Sales Staff)**

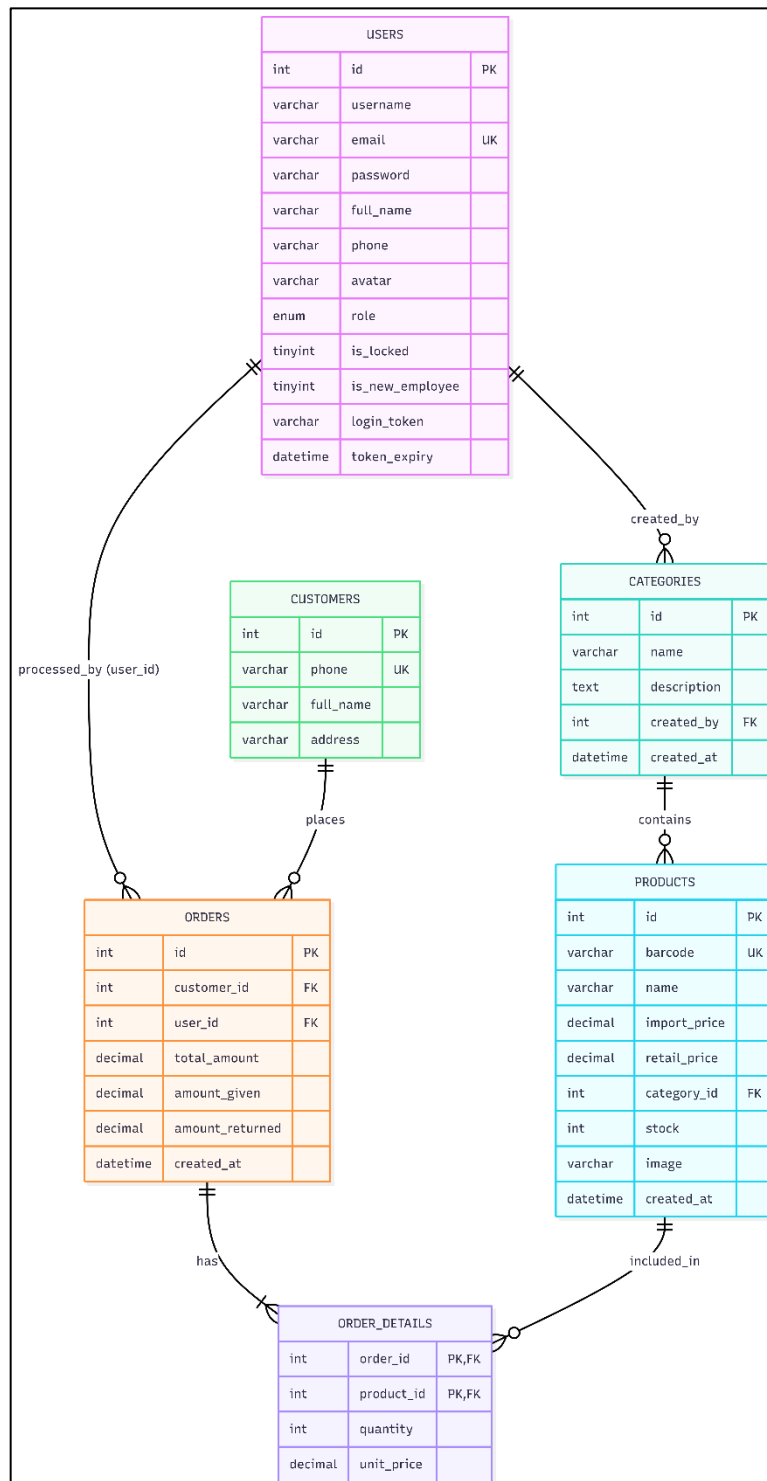
Là người trực tiếp thực hiện các nghiệp vụ bán hàng tại quầy. Các nhóm Use Case chính bao gồm:

- **Hệ thống và Hồ sơ cá nhân:** Đăng nhập, Xem/Cập nhật hồ sơ và Thay đổi mật khẩu. Đặc biệt, đối với nhân viên mới sẽ có Use Case "Đăng nhập lần đầu qua link" đi kèm ràng buộc <<include>> "Bắt buộc tạo mật khẩu mới".
- **Xử lý Giao dịch (POS):** Quản lý giỏ hàng với các thao tác mở rộng (<<extend>> Tìm/Thêm sản phẩm, <<extend>> Cập nhật số lượng), Xem tổng quan đơn hàng, Thanh toán và In hóa đơn.
- **Quản lý Khách hàng:** Được kích hoạt tự động qua luồng POS (<<include>>), cho phép tạo tài khoản khách hàng mới, tra cứu thông tin và lịch sử mua hàng.

Kết luận: Sơ đồ Use Case mô tả đầy đủ chức năng của hệ thống, đồng thời phân chia rõ ràng vai trò giữa Admin và Nhân viên. Việc sử dụng các quan hệ include và extend

thể hiện mối liên kết các chức năng, từ đó làm rõ luồng xử lý nghiệp vụ trong hệ thống.

3.2 Phân tích thiết kế cơ sở dữ liệu thông qua sơ đồ ERD



Hình 3-2. ERD

Sơ đồ ERD mô tả cấu trúc cơ sở dữ liệu của hệ thống website bán hàng trực tiếp. Hệ thống được thiết kế theo mô hình cơ sở dữ liệu quan hệ, bao gồm các thực thể chính như: users, customers, categories, products, orders và order_details. Các thực thể liên kết với nhau thông qua khóa chính và khóa ngoại, đảm bảo tính toàn vẹn và nhất quán dữ liệu, bao gồm **6 thực thể (bảng) chính**:

- **users:** Lưu trữ thông tin người dùng trong hệ thống (Admin và Sales Staff), phục vụ cho đăng nhập, phân quyền và quản lý nhân viên.
 - id (Khóa chính): Định danh duy nhất cho mỗi người dùng.
 - username: Tên đăng nhập của người dùng.
 - email: Email của người dùng (duy nhất)
 - password: Mật khẩu đã được mã hóa.
 - full_name: Họ tên đầy đủ.
 - phone: Số điện thoại.
 - avatar: Ảnh đại diện.
 - role: Phân quyền (admin/staff).
 - is_locked: Trạng thái khóa tài khoản.
 - is_new_employee: Kiểm tra đăng nhập lần đầu.
 - login_token, token_expiry: Phục vụ đăng nhập qua email.
- **customers:** Lưu trữ thông tin khách hàng. Dữ liệu khách hàng được sử dụng trong quá trình thanh toán và tra cứu lịch sử mua hàng
 - id (Khóa chính).
 - phone (duy nhất): Số điện thoại.
 - full_name: Họ tên khách hàng.
 - address: Địa chỉ khách hàng.
- **categories:** Lưu trữ thông tin danh mục. Mỗi danh mục được tạo bởi Admin.
 - id (Khóa chính).
 - name: Tên danh mục.
 - description: Mô tả danh mục.
 - created_by (FK -> USERS): Người tạo danh mục.

- created_at: Thời gian tạo.
- **products:** Lưu trữ thông tin sản phẩm. Mỗi sản phẩm thuộc một danh mục cụ thể.
 - id (Khóa chính).
 - barcode (duy nhất): Mã vạch sản phẩm.
 - name: Tên sản phẩm.
 - import_price: Giá nhập.
 - retail_price: Giá bán.
 - category_id (FK -> CATEGORIES): Danh mục sản phẩm.
 - stock: Số lượng tồn kho.
 - image: Hình ảnh sản phẩm.
 - created_at: Thời gian tạo.
- **orders:** Lưu trữ thông tin đơn hàng. Một đơn hàng gắn với một khách hàng và một nhân viên/người dùng xử lý.
 - id (khóa chính).
 - customer_id (FK -> CUSTOMERS): Khách hàng.
 - user_id (FK -> USERS): Nhân viên thực hiện.
 - total_amount: Tổng tiền đơn hàng.
 - amount_given: Số tiền khách đưa.
 - amount_returned: Số tiền trả lại.
 - created_at: Thời gian tạo đơn.
- **order_details:** Lưu trữ chi tiết sản phẩm trong từng đơn hàng. Đây là bảng trung gian thể hiện mối quan hệ nhiều-nhiều giữa ORDERS và PRODUCTS.
 - order_id (FK -> ORDERS): Mã đơn hàng.
 - product_id (FK -> PRODUCTS): Mã sản phẩm.
 - quantity, unit_price: Giá bán tại thời điểm mua.

Mối quan hệ giữa các thực thể:

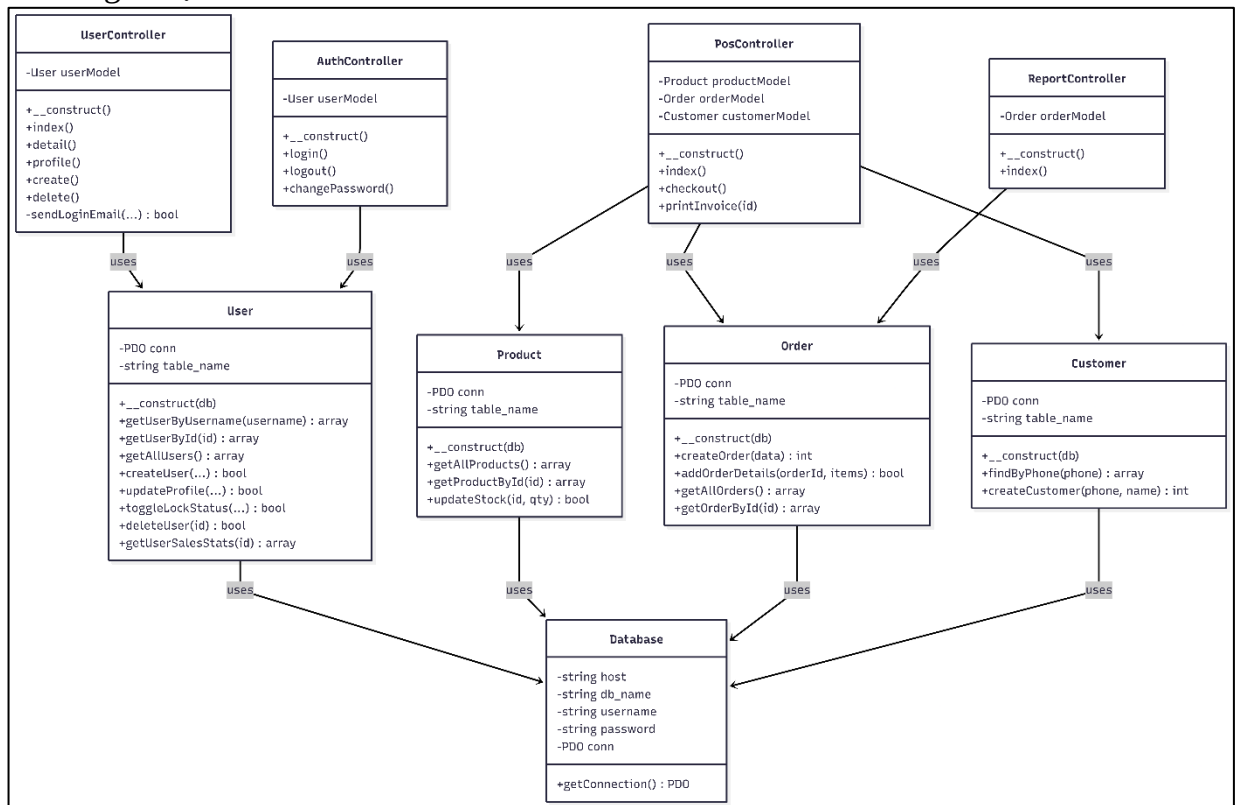
- **users – orders:** Quan hệ 1 – N (1 user có thể xử lý nhiều đơn hàng).
- **customers – orders:** Quan hệ 1 – N (1 khách hàng có thể có nhiều đơn hàng).

- **categoris – products:** Quan hệ 1 – N (1 danh mục chứa nhiều sản phẩm).
- **orders – products:** Quan hệ N – N thông qua bảng ORDER_DETAILS.
- **users – categories:** Quan hệ 1 – N (1 user có thể tạo nhiều danh mục).

Kết luận: Sơ đồ ERD mô tả đầy đủ cấu trúc dữ liệu hệ thống bán hàng, đảm bảo hỗ trợ tốt cho các chức năng như quản lý sản phẩm, xử lý đơn hàng và quản lý người dùng.

3.3 Phân tích kiến trúc thông qua sơ đồ lớp (Class Diagram)

Để thực hiện hóa mô hình MVC, hệ thống phân rã các lớp đối tượng (Classes) thành 3 tầng rõ rệt:



Hình 3-3. Class Diagram

- **Tầng Controller:** Bao gồm các lớp định tuyến và xử lý logic luồng như AuthController, UserController, PosController,... Các lớp này chứa thuộc tính là các đối tượng Model tương ứng và các phương thức public để nhận request (VD: login(), checkout(), create()).

- **Tầng Model:** Chịu trách nhiệm tương tác trực tiếp với cơ sở dữ liệu (CSDL) qua PDO. Tiêu biểu như lớp User (với các hàm `getUserByUsername()`, `createUser()`), lớp Order, lớp Product.
- **Tầng cơ sở (Base/Core):** Lớp Database đóng vai trò Singleton, chứa cấu hình kết nối và cung cấp phương thức `getConnection()` trả về đối tượng PDO duy nhất, giúp tối ưu hóa tài nguyên kết nối.

3.4 Phân tích luồng nghiệp vụ thông qua sơ đồ tuần tự (Sequence Diagram)

Để làm rõ sự tương tác động giữa các thành phần trong mô hình MVC theo thời gian thực, nhóm đã tiến hành thiết kế Sơ đồ tuần tự cho hai luồng nghiệp vụ cốt lõi và phức tạp nhất của hệ thống là xử lý giao dịch và tạo, xác thực tài khoản mới.

3.4.1 Luồng xử lý giao dịch tại quầy

Luồng nghiệp vụ này đòi hỏi sự chính xác tuyệt đối về mặt dữ liệu tài chính và tồn kho. Khi nhân viên xác nhận thanh toán, quá trình xử lý diễn ra qua các bước:

- **Giao tiếp bất đồng bộ:** Giao diện Client (View) đóng gói toàn bộ dữ liệu giỏ hàng và thông tin khách hàng, gửi request thông qua AJAX đến `PosController`.
- **Xử lý Khách hàng:** Controller tương tác với `CustomerModel` để tra cứu số điện thoại. Nếu là khách hàng mới, hệ thống tự động khởi tạo hồ sơ (tạo Customer ID mới) trước khi tiến hành thanh toán.
- **Đảm bảo toàn vẹn dữ liệu (ACID):** `PosController` chuyển giao dữ liệu cho `OrderModel`. Tại đây, một chuỗi giao dịch (Database Transaction) được kích hoạt. Hệ thống lần lượt ghi nhận thông tin tổng quát vào bảng `orders`, duyệt vòng lặp lưu chi tiết vào `order_details` và cập nhật giảm trừ số lượng tồn kho trong bảng `products`.

- Nếu toàn bộ truy vấn thành công, hệ thống thực thi commit() và trả mã trạng thái về Client để tiến hành xuất hóa đơn PDF. Nếu có bất kỳ lỗi nào phát sinh, lệnh rollBack() được gọi để hủy bỏ toàn bộ giao dịch.

3.4.2 Luồng cấp tài khoản và xác thực nhân viên mới

Đây là luồng nghiệp vụ được thiết kế với tiêu chuẩn bảo mật khắt khe, tuân thủ nguyên tắc cấp quyền an toàn:

- **Khởi tạo:** Khi Quản trị viên tạo tài khoản, UserController sẽ sinh ra một chuỗi login_token (UUID) và giới hạn thời gian tồn tại của token này đúng 60 giây. Mật khẩu mặc định được băm bằng thuật toán Bcrypt trước khi lưu vào cơ sở dữ liệu.
- **Gửi thông báo:** Hệ thống tự động kích hoạt thư viện PHPMailer, sử dụng giao thức SMTP để gửi liên kết đăng nhập an toàn chứa token đến email của nhân viên.
- **Xác thực và Cấp quyền:** Khi nhân viên nhấp vào liên kết, AuthController sẽ kiểm tra tính hợp lệ và thời hạn của token. Nếu thỏa mãn điều kiện, hệ thống lưu phiên làm việc tạm thời và ép buộc (force redirect) nhân viên phải thay đổi mật khẩu cá nhân. Chỉ khi quá trình đổi mật khẩu hoàn tất, mã token cũ mới bị hủy bỏ và tài khoản được mở khóa toàn bộ tính năng bán hàng.

(Lưu ý: Nhằm đảm bảo chất lượng hiển thị và tối ưu hóa không gian trình bày của báo cáo, các bản vẽ sơ đồ chi tiết đã được nhóm đính kèm tại thư mục diagram/ trong mã nguồn nộp kèm).

CHƯƠNG 4. HIỆN THỰC HỆ THỐNG

Dựa trên kết quả phân tích và thiết kế kiến trúc, hệ thống 3D Phone POS được hiện thực hóa bằng ngôn ngữ PHP thuần, tuân thủ nghiêm ngặt mô hình MVC. Quá trình xây dựng được chia thành việc tổ chức mã nguồn và lập trình các luồng nghiệp vụ cốt lõi.

4.1 Tổ chức cấu trúc mã nguồn

Toàn bộ mã nguồn dự án được đóng gói trong thư mục `source/` với cấu trúc phân lớp MVC tiêu chuẩn:

- `index.php`: Đóng vai trò Front Controller, điểm vào (entry point) duy nhất của toàn bộ ứng dụng.
- `.env` và `.env.example`: Quản lý các biến môi trường nhạy cảm (cấu hình DB, SMTP credentials) nhằm đảm bảo an toàn bảo mật, không hard-code thông tin trực tiếp vào mã nguồn.
- `controllers/`, `models/`, `views/`: Chứa các tệp tin xử lý tương ứng với 3 tầng của kiến trúc MVC.
- `core/helpers.php`: Tập hợp các hàm tiện ích toàn cục dùng chung cho hệ thống (như hàm định dạng tiền tệ, thuật toán đọc số thành chữ).

4.2 Hiện thực cơ chế Front Controller và Định tuyến (Routing)

Thay vì truy cập trực tiếp vào từng file PHP riêng lẻ, hệ thống định tuyến mọi yêu cầu (Request) thông qua file `index.php`

```

1  <?php
2  // Nạp các biến môi trường từ file .env
3  $envFile = __DIR__ . '/.env';
4  if (file_exists($envFile)) {
5      $lines = file($envFile, FILE_IGNORE_NEW_LINES | FILE_SKIP_EMPTY_LINES);
6      foreach ($lines as $line) {
7          if (strpos(trim($line), '#') === 0) {
8              continue; // Bỏ qua các dòng chú thích
9          }
10         list($name, $value) = explode('=', $line, 2);
11         $name = trim($name);
12         $value = trim($value, " \t\n\r\0\x0B"); // Loại bỏ khoảng trắng và dấu ngoặc kép
13         if (!array_key_exists($name, $_SERVER) && !array_key_exists($name, $_ENV)) {
14             putenv(sprintf('%s=%s', $name, $value));
15             $_ENV[$name] = $value;
16             $_SERVER[$name] = $value;
17         }
18     }
19 }
20
21 session_start();
22
23 require_once 'core/helpers.php';
24
25
26 if (isset($_SESSION['user_id'])) {
27     if ($_SESSION['is_new_employee'] == true) {
28         $currentController = isset($_GET['controller']) ? $_GET['controller'] : '';
29         $currentAction = isset($_GET['action']) ? $_GET['action'] : '';
30
31         if (!($currentController == 'auth' && ($currentAction == 'changePassword' || $currentAction == 'logout'))) {
32             header("Location: index.php?controller=auth&action=changePassword");
33             exit();
34         }
35     }
36 }
37 $controllerName = isset($_GET['controller']) ? $_GET['controller'] : 'auth';
38 $actionName = isset($_GET['action']) ? $_GET['action'] : 'login';
39
40 $controllerClass = ucfirst($controllerName) . 'Controller';
41 $controllerFile = "controllers/" . $controllerClass . ".php";
42
43 if (file_exists($controllerFile)) {
44     require_once $controllerFile;
45
46     $controller = new $controllerClass();
47
48     if (method_exists($controller, $actionName)) {
49         $controller->$actionName();
50     } else {
51         die("Lỗi: Không tìm thấy phương thức xử lý (Action: $actionName)!");
52     }
53 } else {
54     die("Lỗi: Không tìm thấy Controller (File: $controllerFile)!");
55 }
56 ?>

```

file index.php

Giải thích: Cơ chế này đọc tham số `controller` và `action` từ query string (URL), sau đó tự động ánh xạ (map) để khởi tạo đối tượng Controller tương ứng và gọi đúng phương thức xử lý. Cách làm này giúp tập trung hóa việc kiểm soát luồng dữ liệu, tạo tiền đề để dễ dàng tích hợp các lớp kiểm tra bảo mật (Middleware).

4.3 Hiện thực cơ chế Middleware bảo vệ và phân quyền

Việc kiểm soát quyền truy cập (Authorization) được thực hiện bằng một dạng Middleware thủ công, đặt ngay trong hàm khởi tạo (`__construct()`) của các Controller.



```

1 public function __construct() {
2     if (!isset($_SESSION['user_id'])) {
3         header("Location: index.php?controller=auth&action=login");
4         exit();
5     }
6 }

```

kiểm tra session trong `__construct()` của `ReportController.php`

Giải thích: Nếu người dùng chưa đăng nhập hoặc không đủ thẩm quyền, hệ thống sẽ sử dụng lệnh `header("Location: ...")` để điều hướng về trang đăng nhập hoặc trang báo lỗi 403 thay vì dùng lệnh `die()` gây trắng trang, từ đó đảm bảo trải nghiệm người dùng (UX) và tính bảo mật của hệ thống.

4.4 Hiện thực luồng thuật toán tạo nhân viên mới

Đây là một luồng nghiệp vụ phức tạp đòi hỏi tính bảo mật cao, được hiện thực qua các bước tuần tự:

1. **Khởi tạo:** Admin tạo tài khoản. Hệ thống sinh ngẫu nhiên một chuỗi `login_token` (UUID) và đặt thời hạn `token_expiry` là 60 giây kể từ lúc tạo.
2. **Gửi liên kết:** Thư viện PHPMailer lấy cấu hình từ tệp `.env` để gửi email chứa link xác thực qua giao thức SMTP đến nhân viên.
3. **Xác thực và Giới hạn:** Khi nhân viên nhấp vào liên kết, `AuthController` đối chiếu token và thời gian. Nếu hợp lệ, hệ thống khởi tạo phiên làm việc với cờ `is_new_employee = true`. Lúc này, Front Controller sẽ khóa mọi điều hướng khác và bắt buộc người dùng chuyển thẳng đến trang Đổi mật khẩu.

4. **Hoàn tất:** Nhân viên thiết lập mật khẩu mới (được băm bằng Bcrypt). Hệ thống xóa token, cập nhật trạng thái nhân viên chính thức và cho phép truy cập hệ thống POS.

4.5 Hiện thực luồng xử lý giao dịch POS (Thanh toán thời gian thực)

Luồng POS được thiết kế để tối ưu hóa tốc độ thao tác tại quầy, áp dụng kỹ thuật AJAX và đảm bảo toàn vẹn dữ liệu bằng PDO Transaction:

1. **Tương tác Frontend:** Giao diện cho phép tìm kiếm sản phẩm bằng mã vạch hoặc tên. JavaScript (AJAX) gửi request lên PosController để nhận về dữ liệu JSON và render lại giỏ hàng ngay lập tức mà không cần tải lại trang (reload). Đồng thời, hàm JavaScript tính toán và dịch tổng số tiền sang chữ tiếng Việt theo thời gian thực.
2. **Xử lý Backend (Checkout):** Dữ liệu giỏ hàng và khách hàng được gửi về máy chủ. Tại đây, PosController khởi tạo một PDO Transaction. Hệ thống lần lượt:

Gọi phương thức `findByPhone()` để tra cứu và tạo/cập nhật thông tin khách hàng → Lưu tiêu đề đơn hàng (`orders`) → Lưu chi tiết từng sản phẩm (`order_details`) → Trừ số lượng tồn kho (`products`).

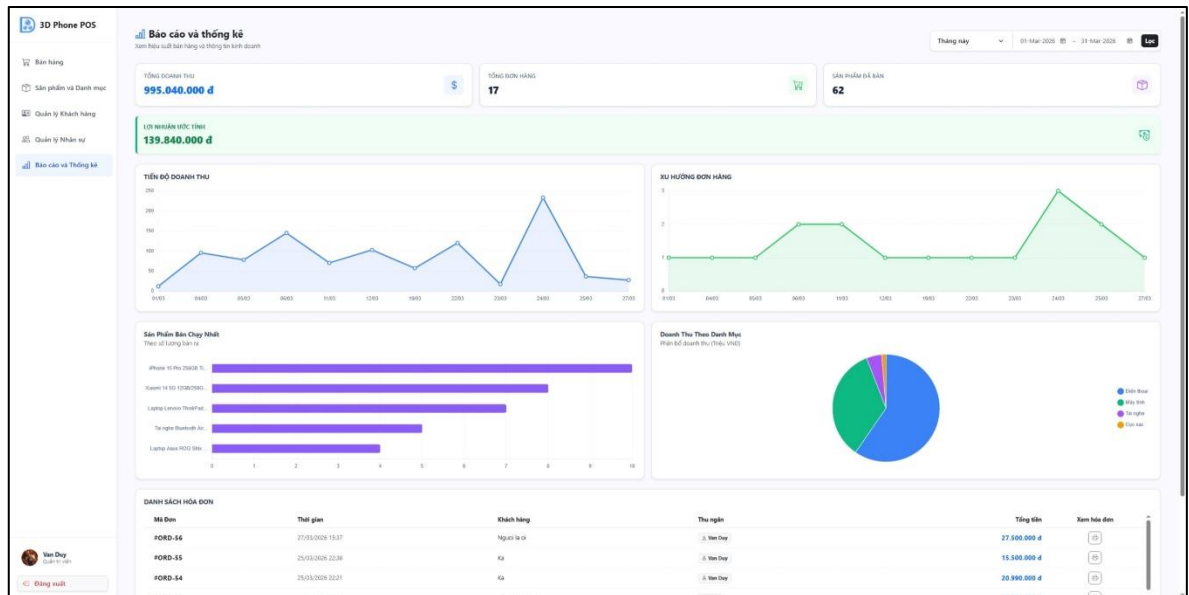
3. **Đảm bảo tính ACID:** Nếu bất kỳ truy vấn nào trong chuỗi trên bị lỗi, lệnh `rollback()` sẽ được gọi để hoàn tác toàn bộ thao tác, tránh tình trạng dữ liệu bất đồng bộ. Nếu thành công, lệnh `commit()` được thực thi và hệ thống gọi thư viện **Dompdf** để xuất hóa đơn PDF trực tiếp trên trình duyệt.

CHƯƠNG 5. KẾT QUẢ ĐẠT ĐƯỢC

5.1 Giao diện và chức năng đã hoàn thành

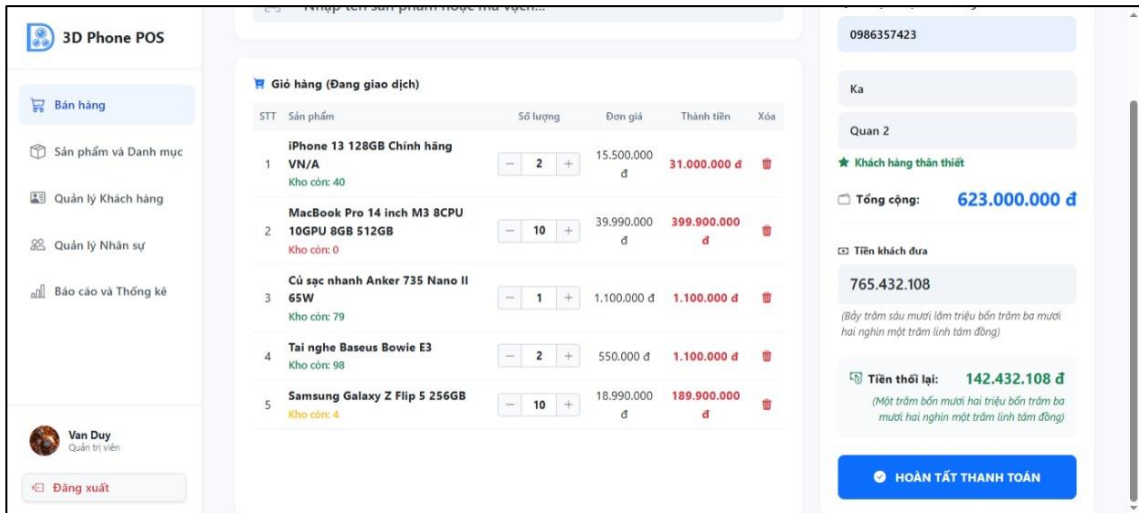
Hệ thống 3D Phone POS đã hiện thực hóa thành công toàn bộ các chức năng theo yêu cầu đề tài (đạt 100% mục tiêu đề ra), vận hành trơn tru trên môi trường thực tế với các mô-đun chính:

- **Giao diện Tổng quan và Báo cáo (Dashboard):** Trực quan hóa dữ liệu doanh thu, số lượng đơn hàng và lợi nhuận bằng biểu đồ Chart.js, cho phép lọc theo nhiều mốc thời gian.



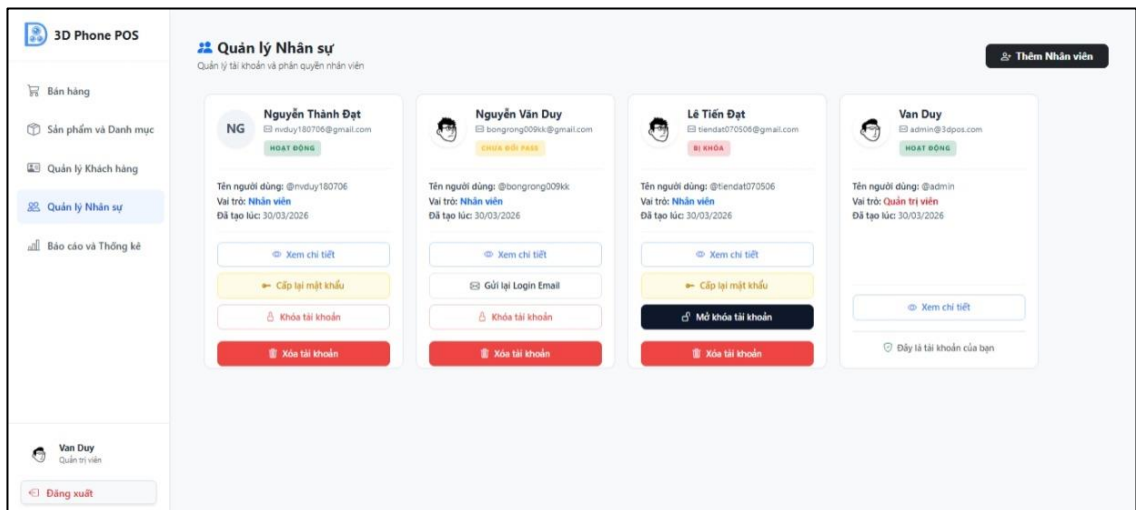
Hình 5-1. Giao diện Báo cáo và Thống kê dành cho Quản trị viên

- **Giao diện Xử lý Giao dịch (POS):** Thiết kế tối ưu cho thao tác tại quầy, cập nhật giỏ hàng theo thời gian thực (real-time) và tính toán tổng tiền, tiền thừa tự động.



Hình 5-2. Giao diện màn hình POS hỗ trợ tìm kiếm sản phẩm và thanh toán

- **Các mô-đun Quản lý (CRUD):** Các chức năng Quản lý Nhân viên, Quản lý Sản phẩm, Danh mục và Khách hàng đều được thiết kế thân thiện, responsive, hỗ trợ các nhãn trạng thái (badge) rõ ràng và phân quyền hiển thị đúng vai trò.



Hình 5-3. Giao diện danh sách quản lý nhân viên trong hệ thống

5.2 Năm điểm kỹ thuật nổi bật

Bên cạnh việc hoàn thiện giao diện, hệ thống còn đạt được những kết quả xuất sắc về mặt kiến trúc và tối ưu hóa hệ thống:

- **Điểm 1: Bảo mật đa tầng với Bcrypt và Biến môi trường**

Toàn bộ mật khẩu trong hệ thống không bị lưu dưới dạng văn bản thuần mà được băm (hash) bảo mật bằng thuật toán Bcrypt thông qua hàm `password_hash()` của PHP. Đặc biệt, hệ thống có cơ chế tự động băm lại mật khẩu (Password Migration) khi nhân viên mới đăng nhập lần đầu.

Cấu hình nhạy cảm SMTP được tách biệt hoàn toàn vào tệp `.env`, ngăn chặn rủi ro lộ lọt thông tin mã nguồn.

- **Điểm 2: Tối ưu hóa truy vấn cơ sở dữ liệu (SARGable Queries)**

Thay vì sử dụng các hàm bọc cột thời gian (ví dụ: `DATE(created_at)`) gây ra tình trạng Full Table Scan, toàn bộ các truy vấn thống kê trong Model Order được chuẩn hóa theo dạng **SARGable** (sử dụng toán tử `BETWEEN`). Kỹ thuật này giúp MySQL tận dụng tối đa Index B-Tree, đảm bảo hệ thống vẫn phản hồi nhanh chóng ($O(\log N)$) ngay cả khi lượng dữ liệu đơn hàng tăng cao.

- **Điểm 3: Thuật toán dịch số tiền thành chữ tiếng Việt:** Hệ thống tự động hóa trải nghiệm thanh toán bằng cách tích hợp thuật toán dịch số tiền thành chữ. Thuật toán được xử lý đồng bộ ở hai tầng:

- Tầng Client (JavaScript) dịch thời gian thực khi nhân viên nhập số tiền trên màn hình POS.
- Tầng Server (PHP) xử lý khi in hóa đơn PDF, xử lý tính tế các trường hợp ngữ pháp đặc thù như "lẻ", "mốt", "lăm".

- **Điểm 4: Kiểm duyệt dữ liệu (Validation) toàn diện:** Tính toàn vẹn của dữ liệu được bảo vệ nghiêm ngặt bằng quy trình Validation hai lớp:

- Lớp Client (JavaScript) kiểm tra và phản hồi lỗi tức thì (ví dụ: cấm nhập giá âm, mã vạch trống) để tăng UX.
- Lớp Server (PHP) đóng vai trò chốt chặn cuối cùng, lọc toàn bộ đầu vào và đầu ra qua hàm `htmlspecialchars()` nhằm ngăn chặn triệt để tấn công XSS (Cross-Site Scripting).

- **Điểm 5: Cơ chế Onboarding bằng Token 1 phút**

Quy trình cấp quyền cho nhân viên mới được tự động hóa qua email với độ an toàn cao. Liên kết đăng nhập sinh ra từ token UUID chỉ có hiệu lực đúng 60 giây và hệ thống tự động khóa luồng, bắt buộc người dùng mới phải thiết lập mật khẩu cá nhân trước khi được phép thao tác bất kỳ chức năng nào khác.

5.3 Kết quả kiểm thử hệ thống

Để đảm bảo chất lượng phần mềm và tính chính xác của các luồng nghiệp vụ cốt lõi, nhóm đã tiến hành kiểm thử dựa trên các kịch bản sử dụng thực tế. Dưới đây là bảng tổng hợp các ca kiểm thử quan trọng nhất đã được thực thi và nghiệm thu thành công trên hệ thống:

Mã Test Case	Tên chức năng	Các bước thực hiện	Kết quả mong đợi	Kết quả thực tế	Trạng thái
TC_01	Đăng nhập Admin	1. Nhập username admin 2. Nhập password 3. Bấm Đăng nhập	Chuyển hướng đến trang Report (Báo cáo và Thống kê)	Đúng như mong đợi	Pass
TC_02	Đăng nhập Sales Staff	1. Nhập username staff 2. Nhập password 3. Bấm Đăng nhập	Chuyển hướng đến trang POS (Bán hàng)	Đúng như mong đợi	Pass
TC_03	Đăng nhập sai thông tin	1. Nhập sai username hoặc password 2. Bấm Đăng nhập	Hiển thị thông báo lỗi "Tên đăng nhập hoặc mật khẩu không đúng"	Đúng như mong đợi	Pass
TC_04	Đổi mật khẩu (Hợp lệ)	1. Nhập đúng mật khẩu cũ	Cập nhật mật khẩu thành công, hiển thị thông báo	Đúng như	Pass

Mã Test Case	Tên chức năng	Các bước thực hiện	Kết quả mong đợi	Kết quả thực tế	Trạng thái
		2. Nhập mật khẩu mới (>6 ký tự) 3. Xác nhận lại mật khẩu mới khớp nhau		mong đợi	
TC_05	Tìm kiếm sản phẩm bằng tên (POS)	1. Nhập tên sản phẩm vào ô tìm kiếm (vd: iPhone)	Hiển thị danh sách các sản phẩm có chứa từ khóa "iPhone"	Đúng như mong đợi	Pass
TC_06	Tìm kiếm sản phẩm bằng mã vạch	1. Nhập chính xác mã vạch sản phẩm	Tự động thêm thẳng 1 sản phẩm đó vào giỏ hàng	Đúng như mong đợi	Pass
TC_07	Thêm sản phẩm vào giỏ (Còn hàng)	1. Bấm nút (+) trên sản phẩm có tồn kho > 0	Sản phẩm hiện trong giỏ, số lượng 1, tổng tiền cập nhật	Đúng như mong đợi	Pass
TC_08	Thêm sản phẩm vào giỏ (Hết hàng)	1. Bấm nút (+) trên sản phẩm có tồn kho = 0	Hiển thị cảnh báo lỗi "Sản phẩm đã hết hàng"	Đúng như mong đợi	Pass
TC_09	Cập nhật số lượng giỏ hàng	1. Bấm nút (+) hoặc (-) trong giỏ hàng	Số lượng thay đổi, thành tiền và tổng đơn hàng cập nhật theo	Đúng như mong đợi	Pass
TC_10	Xóa sản phẩm khỏi giỏ hàng	1. Bấm nút (Thùng rác) cạnh sản phẩm trong giỏ	Sản phẩm biến mất khỏi giỏ, tổng tiền giảm tương ứng	Đúng như mong đợi	Pass
TC_11	Thanh toán (khách hàng Mới)	1. Nhập SĐT mới	Lưu khách hàng mới, tạo đơn hàng, trừ kho,	Đúng như	Pass

Mã Test Case	Tên chức năng	Các bước thực hiện	Kết quả mong đợi	Kết quả thực tế	Trạng thái
		2. Điền Tên, Địa chỉ 3. Nhập tiền khách đưa 4. Bấm Hoàn tất	mở tab in hóa đơn PDF	mong đợi	
TC_12	Thanh toán (khách hàng Cũ)	1. Nhập SĐT cũ 2. Hệ thống tự điền Tên/Địa chỉ 3. Bấm Hoàn tất	Gắn đơn hàng cho khách hàng cũ, trừ kho, mở tab in hóa đơn PDF	Đúng như mong đợi	Pass
TC_13	Xem báo cáo và thống kê (Admin)	1. Đăng nhập tài khoản Admin 2. Truy cập Báo cáo và Thống kê 3. Tự động xem báo cáo và thống kê đơn hàng trong ngày “Hôm nay”	Hiển thị đầy đủ 4 biểu đồ và danh sách đơn hàng. Hiện thêm mục “Lợi nhuận ước tính”	Đúng như mong đợi	Pass
TC_14	Xem báo cáo và thống kê (Sales Staff)	1. Đăng nhập tài khoản Sales Staff 2. Truy cập Báo cáo và Thống kê 3. Tự động xem báo cáo và thống kê đơn hàng trong ngày “Hôm nay”	Hiển thị đầy đủ 4 biểu đồ và danh sách đơn hàng. Ấn mục “Lợi nhuận ước tính”	Đúng như mong đợi	Pass
TC_15	Lọc báo cáo theo ngày	1. Chọn Từ ngày - Đến ngày 2. Bấm Lọc	Dữ liệu biểu đồ và các chỉ số (Doanh thu, Lợi	Đúng như	Pass

Mã Test Case	Tên chức năng	Các bước thực hiện	Kết quả mong đợi	Kết quả thực tế	Trạng thái
			nhuận) thay đổi tương ứng	mong đợi	
TC_16	Xem chi tiết đơn hàng	1. Bấm vào icon máy in ở cuối mỗi đơn hàng trong danh sách đơn hàng	Mở tab in hóa đơn PDF thanh toán của đơn hàng.	Đúng như mong đợi	Pass

CHƯƠNG 6. KẾT LUẬN

6.1 Những kết quả đã đạt được và ưu điểm của hệ thống

Sau quá trình phân tích, thiết kế và hiện thực, nhóm đã xây dựng thành công Hệ thống quản lý bán hàng điện thoại (3D Phone POS) đáp ứng trọn vẹn các yêu cầu của đề tài. Hệ thống mang lại những ưu điểm nổi bật như sau:

- **Kiến trúc phần mềm chuẩn mực:** Việc tự xây dựng mô hình MVC bằng PHP thuần giúp mã nguồn phân tách rõ ràng giữa giao diện, luồng điều khiển và dữ liệu. Cấu trúc này không chỉ giúp code dễ đọc, dễ bảo trì mà còn tạo nền tảng vững chắc để mở rộng tính năng sau này.
- **Bảo mật toàn diện:** Hệ thống áp dụng các tiêu chuẩn bảo mật hiện đại như băm mật khẩu bằng Bcrypt, sử dụng Prepared Statements để phòng chống SQL Injection, dùng htmlspecialchars() chặn XSS, và ẩn giấu cấu hình nhạy cảm trong tệp .env.
- **Trải nghiệm người dùng (UX) tối ưu:** Giao diện POS phản hồi mượt mà nhờ công nghệ AJAX cập nhật thời gian thực, kết hợp với các tiện ích tự động hóa như hóa đơn PDF chuyên nghiệp và thuật toán đọc số tiền bằng chữ tiếng Việt.
- **Hiệu năng cơ sở dữ liệu ổn định:** Các truy vấn thống kê được viết theo chuẩn SARGable, đảm bảo hệ thống có khả năng tận dụng Index và duy trì tốc độ phản hồi nhanh ngay cả khi lượng dữ liệu bán hàng tăng lên trong tương lai.

6.2 Khuyết điểm và Hạn chế

Bên cạnh những kết quả đạt được, do giới hạn về mặt thời gian triển khai của một đề án môn học, hệ thống vẫn còn một số hạn chế nhất định:

- **Giới hạn mô hình kinh doanh:** Kiến trúc cơ sở dữ liệu hiện tại được thiết kế tối ưu cho một cửa hàng bán lẻ đơn lẻ, chưa hỗ trợ nghiệp vụ cho chuỗi hệ thống đa chi nhánh.
- **Quản lý tồn kho cơ bản:** Hệ thống mới chỉ dừng ở mức tự động trừ/cộng số lượng khi có giao dịch mua bán. Các nghiệp vụ quản lý kho chuyên sâu như lập phiếu nhập kho (Purchase Order), kiểm kê định kỳ hay cảnh báo sắp hết hàng chưa được tích hợp.
- **Phương thức thanh toán:** Hệ thống xử lý giao dịch POS hiện tại chỉ mới hỗ trợ ghi nhận thanh toán bằng tiền mặt, chưa kết nối trực tiếp với các cổng thanh toán điện tử.
- **Bảo mật thao tác người dùng (CSRF):** Hệ thống hiện tại chưa tích hợp mã thông báo chống giả mạo request liên trang (CSRF Tokens) cho các form tương tác. Điều này tạo ra rủi ro tiềm ẩn nếu người dùng vô tình truy cập các trang web độc hại khi phiên đăng nhập vẫn còn hiệu lực.

6.3 Hướng phát triển tương lai

Từ những hạn chế trên, nhóm đề xuất các hướng phát triển mở rộng cho hệ thống trong tương lai nhằm đáp ứng trọn vẹn hơn nhu cầu vận hành thực tế của các doanh nghiệp bán lẻ:

- **Tích hợp cơ chế bảo mật CSRF Token:** Nâng cấp an toàn hệ thống bằng cách tự động sinh mã thông báo (Token) độc nhất cho mỗi phiên làm việc. Mọi request làm thay đổi dữ liệu (POST, DELETE) từ form hoặc AJAX đều bắt buộc đính kèm token này để kiểm duyệt tại tầng Middleware.
- **Nâng cấp trải nghiệm thanh toán tại quầy (POS):** Bổ sung tính năng "Lưu tạm đơn hàng" (Hold / Recall Order). Tính năng này cho phép thu ngân treo phiên giao dịch hiện tại vào bộ nhớ tạm khi khách hàng cần thêm thời gian,

giúp phục vụ ngay khách hàng tiếp theo và tối ưu hóa luồng hàng đợi trong giờ cao điểm.

- **Bổ sung phân hệ Đổi trả và Hủy đơn:** Xây dựng quy trình xử lý đổi trả hàng hóa (Return/Refund) và hủy hóa đơn (Void) với cơ chế phân quyền quản lý chặt chẽ. Việc này đi kèm với tự động hoàn trả tồn kho (Restock) và lưu vết đối soát tài chính minh bạch (Audit Trail), tuân thủ nghiêm ngặt các nguyên tắc kế toán.
- **Hoàn thiện mô-đun Quản lý kho:** Xây dựng tính năng quản lý nhà cung cấp, lập phiếu nhập hàng (Purchase Order) và hệ thống cảnh báo tồn kho tự động.
- **Tích hợp thanh toán trực tuyến:** Kết nối hệ thống với các cổng thanh toán hiện đại (Momo, VNPay) hoặc API tạo mã VietQR động để đa dạng hóa phương thức thanh toán, hạn chế rủi ro thất thoát tiền mặt.
- **Tích hợp phần cứng quét mã:** Nâng cấp mô-đun tìm kiếm sản phẩm tại quầy POS bằng cách sử dụng API `getUserMedia` để đọc mã vạch trực tiếp từ camera của trình duyệt web hoặc thiết bị di động.
- **Phát triển nền tảng di động:** Xây dựng các API RESTful từ Backend hiện tại để hỗ trợ phát triển thêm ứng dụng di động (Mobile App) dành riêng cho quản lý theo dõi báo cáo từ xa hoặc nhân viên chốt sale lưu động.

TÀI LIỆU THAM KHẢO

[1] PHP Documentation, “PHP Manual,”: <https://www.php.net/manual/en/>.

[2] MySQL Documentation, “MySQL 8.0 Reference Manual,”:

<https://dev.mysql.com/doc/refman/8.0/en/>.

[3] PHPMailer, “PHPMailer – A full-featured email creation and transfer class for PHP,”:

<https://github.com/PHPMailer/PHPMailer>.

[4] Dompdf Project, “Dompdf – HTML to PDF converter,”:

<https://github.com/dompdf/dompdf>.

[5] Bootstrap, “Bootstrap 5 Documentation,”: <https://getbootstrap.com/docs/5.0/>.

[6] Chart.js, “Chart.js Documentation,”: <https://www.chartjs.org/docs/latest/>.

[7] jQuery, “jQuery API Documentation,”: <https://api.jquery.com/>.

[8] OWASP Foundation, “OWASP Top Ten Security Risks,”: <https://owasp.org/www-project-top-ten/>.

[9] PHP: The Right Way, “PHP Best Practices,” : <https://phptherightway.com/>.